Cybersecurity Daily Newsletter

Vol. 007 | 2026-11-13 09:00 WIB

Top 5 Highlights

• FBI Says US Seized $1.2 Billion Worth of Cryptocurrency Stolen From Binance

• ISC Stormcast For Friday, November 13th, 2026
https://isc.sans.edu/podcastdetail/10178, (Fri, Nov 13th)

• Open WebUI: the Windows installer mints the master key from the install second - CVE-2025-15603 was rejected; here is the measurement

• AI Didn’t Create a New Kind of Risk. It Removed the Time You Had to Fix the Old One.

• APPLE-SA-11-12-2026-1 HomeView Software Version 27.2

Threat Intelligence (10)

01. ISC Stormcast For Friday, November 13th, 2026 https://isc.sans.edu/podcastdetail/10178, (Fri, Nov 13th)

ISC Stormcast For Friday, November 13th, 2026 https://isc.sans.edu/podcastdetail/10178, (Fri, Nov 13th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://isc.sans.edu/diary/rss/33516

02. APPLE-SA-11-12-2026-1 HomeView Software Version 27.2

Posted by Apple Product Security via Fulldisclosure on Nov 12 APPLE-SA-11-12-2026-1 HomeView Software Version 27.2 HomeView Software Version 27.2 addresses the following issues. Information about the security content is also available at https://support.apple.com/149851…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://seclists.org/fulldisclosure/2026/Nov/33

03. APPLE-SA-11-09-2026-9 visionOS 27.2.1

Posted by Apple Product Security via Fulldisclosure on Nov 12 APPLE-SA-11-09-2026-9 visionOS 27.2.1 visionOS 27.2.1 addresses the following issues. Information about the security content is also available at https://support.apple.com/149724…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://seclists.org/fulldisclosure/2026/Nov/32

04. APPLE-SA-11-09-2026-8 watchOS 26.6.1

Posted by Apple Product Security via Fulldisclosure on Nov 12 APPLE-SA-11-09-2026-8 watchOS 26.6.1 watchOS 26.6.1 addresses the following issues. Information about the security content is also available at https://support.apple.com/149723…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://seclists.org/fulldisclosure/2026/Nov/31

05. APPLE-SA-11-09-2026-7 watchOS 27.2.1

Posted by Apple Product Security via Fulldisclosure on Nov 12 APPLE-SA-11-09-2026-7 watchOS 27.2.1 watchOS 27.2.1 addresses the following issues. Information about the security content is also available at https://support.apple.com/149722…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://seclists.org/fulldisclosure/2026/Nov/30

06. APPLE-SA-11-09-2026-6 macOS Sequoia 15.8.3

Posted by Apple Product Security via Fulldisclosure on Nov 12 APPLE-SA-11-09-2026-6 macOS Sequoia 15.8.3 macOS Sequoia 15.8.3 addresses the following issues. Information about the security content is also available at https://support.apple.com/149720…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://seclists.org/fulldisclosure/2026/Nov/29

07. APPLE-SA-11-09-2026-5 macOS Tahoe 26.7.3

Posted by Apple Product Security via Fulldisclosure on Nov 12 APPLE-SA-11-09-2026-5 macOS Tahoe 26.7.3 macOS Tahoe 26.7.3 addresses the following issues. Information about the security content is also available at https://support.apple.com/149719…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://seclists.org/fulldisclosure/2026/Nov/28

08. APPLE-SA-11-09-2026-4 macOS Golden Gate 27.2.1

Posted by Apple Product Security via Fulldisclosure on Nov 12 APPLE-SA-11-09-2026-4 macOS Golden Gate 27.2.1 macOS Golden Gate 27.2.1 addresses the following issues. Information about the security content is also available at https://support.apple.com/149718…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://seclists.org/fulldisclosure/2026/Nov/27

09. APPLE-SA-11-09-2026-3 iOS 18.7.12 and iPadOS 18.7.12

Posted by Apple Product Security via Fulldisclosure on Nov 12 APPLE-SA-11-09-2026-3 iOS 18.7.12 and iPadOS 18.7.12 iOS 18.7.12 and iPadOS 18.7.12 addresses the following issues. Information about the security content is also available at https://support.apple.com/149717…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://seclists.org/fulldisclosure/2026/Nov/26

10. APPLE-SA-11-09-2026-2 iOS 26.7.3 and iPadOS 26.7.3

Posted by Apple Product Security via Fulldisclosure on Nov 12 APPLE-SA-11-09-2026-2 iOS 26.7.3 and iPadOS 26.7.3 iOS 26.7.3 and iPadOS 26.7.3 addresses the following issues. Information about the security content is also available at https://support.apple.com/149716…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://seclists.org/fulldisclosure/2026/Nov/25

Latest Vulnerabilities (10)

01. Open WebUI: the Windows installer mints the master key from the install second - CVE-2025-15603 was rejected; here is the measurement

Posted by theknell--- via Fulldisclosure on Nov 12 Open WebUI's Windows installer (start_windows.bat) generates WEBUI_SECRET_KEY - the master secret that signs every session token - from the C library's rand(), a linear congruential generator seeded once with the current time in seconds. The key's entire entropy is the second in which the software was insta…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://seclists.org/fulldisclosure/2026/Nov/21

02. AI Didn’t Create a New Kind of Risk. It Removed the Time You Had to Fix the Old One.

Mandiant’s AI Risk and Resilience 2026 report shows attackers putting agentic AI to work across the intrusion. Vulnerability exploitation is still the leading way in, and the window to fix it is closing. Executive Summary Mandiant and Google Threat Intelligence Group (GTIG) published AI Risk and Resilience 2026 in September. Attackers now use agentic AI […]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://blog.qualys.com/product-tech/2026/11/12/ai-didnt-create-a-new-kind-of-risk-it-removed-the-time-you-had-to-fix-the-old-one

03. [REVIVE-SA-2026-004] Revive Adserver Vulnerabilities

Posted by Matteo Beccati on Nov 12 ========== ========== Revive Adserver Security Advisory REVIVE-SA-2026-004 ---------- https://www.revive-adserver.com/security/revive-sa-2026-004 ----------…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://seclists.org/fulldisclosure/2026/Nov/23

04. AI Source Code Analysis Detection Evasion Techniques

Posted by E. Kellinis on Nov 12 This post investigates whether the source code of a program can be presented in such a way so that a large language model based analysis fails to report a defect that is genuinely present. https://cipher.org.uk/2026/11/06/AI-Source-Code-Analysis-Detection-Evasion-Techniques/

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://seclists.org/fulldisclosure/2026/Nov/18

05. VU#644655: TightVNC and UltraVNC Viewer contains a heap-based buffer overflow

Overview A heap-based buffer overflow exists in the Tight JPEG decoding component of the TightVNC Windows Viewer version 1.3.10 and affected UltraVNC Windows Viewers. An attacker controlling a malicious VNC server can trigger memory corruption by sending a specially crafted screen update. Successful exploitation can crash the viewer and may allow arbitrary…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://kb.cert.org/vuls/id/644655

06. ConnectWise investigating reports of unauthorized access to third-party extensions

Attackers may be exploiting ScreenConnect extensions to execute malicious commands on endpoints.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/news/connectwise-investigating-reports-of-unauthorized-access-to-third-party-extensions

07. New N-able "4EverAble2Shell" zero-day exploited hours after PoC released

Hackers are actively exploiting a newly disclosed N-able N-central zero-day vulnerability dubbed "4EverAble2Shell" to compromise servers and deploy cryptocurrency miners, with researchers reporting at least 21 affected systems, including 19 running the company's latest security update. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/new-n-able-4everable2shell-zero-day-exploited-hours-after-poc-released/

08. Complying with CISA: How continuous analysis aligns with BOD 26-04

Why CISA changed the vulnerability-management rules, and how this might affect you.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/resource/complying-with-cisa-how-continuous-analysis-aligns-with-bod-26-04

09. Apache HTTP Server patches critical HTTP/2 remote code execution flaw

A critical vulnerability in the HTTP/2 module of Apache HTTP Server could be exploited by an unauthenticated attacker to obtain remote code execution (RCE). [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/apache-http-server-patches-critical-http-2-remote-code-execution-flaw/

10. VU#580079: Arbitrary file read/write vulnerability in ImageMagick-based applications with default configuration

Overview Multiple arbitrary file read and write vulnerabilities have been identified in applications that use ImageMagick with insufficiently restrictive security policies. Collectively referred to as ImageTragick2 , these issues arise when ImageMagick processes attacker-controlled SVG or PostScript content using dangerous coders or delegates permitted by i…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://kb.cert.org/vuls/id/580079

Data Breach & Cybercrime (10)

01. FBI Says US Seized $1.2 Billion Worth of Cryptocurrency Stolen From Binance

Also Thursday, the FBI blamed North Korea for a separate social engineering scheme that officials say resulted in the theft of $400 million worth of cryptocurrency. The post FBI Says US Seized $1.2 Billion Worth of Cryptocurrency Stolen From Binance appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.securityweek.com/fbi-says-us-seized-1-2-billion-worth-of-cryptocurrency-stolen-from-binance/

02. Notion discloses data exposure following security breach at AI vendor

As noted by Bleeping Computer, the digital workspace platform Notion recently disclosed that a security breach at its AI infrastructure provider, Fireworks AI, resulted in the exposure of Notion AI chat transcripts within a limited number of workspaces.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/notion-discloses-data-exposure-following-security-breach-at-ai-vendor

03. Extortion Group Luna Moth Flits Into Law Firms a Second Time

The cybercriminals are retargeting law firms that refused to pay its first ransom, with a social engineering con aimed at stealing Microsoft access tokens.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.darkreading.com/data-privacy/extortion-luna-moth-law-firms-second-time

04. ThreatsDay: 59 Linux Kernel Bugs, Falcon Spyware, GSocket Backdoors + 17 More Stories

A search result isn't always safe. An access request isn't always harmless. And a familiar account doesn't always mean a familiar person is using it. Simple things to remember. Yet a surprising amount of this week's trouble starts right there. Attackers are using fake websites, stolen access, and trusted tools to get into places they shouldn't be. AI is hel…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/11/threatsday-59-linux-kernel-bugs-falcon.html

05. Apify rotates API tokens, prompts 2FA resets after breach

Apify has rotated critical internal secrets and revoked some third-party OAuth connections after detecting unauthorized access to its internal systems. […]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/apify-rotates-api-tokens-prompts-2fa-resets-after-breach/

06. Stolen Claude API keys can turn Claude Code into a remote-controlled implant

Darktrace researchers turned Claude Code into a remote-controlled implant in a lab test, steering the coding agent through the memory stores feature of Anthropic’s Claude platform and pulling a 1 GB file out through the Claude Files API. Once the agent was set up, every job and every result traveled through api.anthropic.com, the endpoint the agent already…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.helpnetsecurity.com/2026/11/12/stolen-claude-api-keys-remote-controlled-implant/

07. Inside an AI Attack Against a US Retailer

When hand-typed commands failed to breach a US retailer, the attacker turned to AI-generated scripts, achieving lateral movement in minutes.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.darkreading.com/cyberattacks-data-breaches/inside-ai-attack-us-retailer

08. Why scammers want you to allow push notifications

Browser push notifications are a common nuisance, and they can make people think their device is infected with adware.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.malwarebytes.com/blog/mobile/2026/11/why-scammers-want-you-to-allow-notifications

09. Photos: IRISSCON 2026 cybercrime conference

IRISSCON 2026, the annual cybercrime conference organized by IRISSCERT, took place at the Aviva Stadium in Dublin on November 11. The all-day event gives attendees a look at the cyber threats businesses are facing right now, along with practical advice on how organizations can respond to them. Help Net Security was there, and here’s a look at the day. Visit…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.helpnetsecurity.com/2026/11/12/irisscon-2026-photos/

10. [+24h Old] Maersk Reveals Data Breach as Extortion Group Demands $5m

Maersk has revealed a threat actor extracted data from one of its legacy systems

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.infosecurity-magazine.com/news/maersk-data-breach-extortion-group/